

Contents

Reviewnotitie: Harmonisatie authenticatie (BgZ / eOverdracht)	1
1. Managementsamenvatting	1
2. Belangrijkste issues	2
3. Details per onderdeel	3

Reviewnotitie: Harmonisatie authenticatie (BgZ / eOverdracht)

Document onder review: V2-Harmonisatie-authenticatie.md (wiki-commit fcd9c0e) Reviewer: Jeroen. Geordende versie; de volledige per-zin-uitwerking staat in REVIEW-notitie-ruw.md.

Toon vooraf: dit is veel feedback, maar bedoeld als opbouwend. De richting van de nota (één federatief model op bestaande standaarden) is verdedigbaar en op onderdelen al goed uitgewerkt. De onderstaande punten zijn bedoeld om dat sterker en beter navolgbaar te maken, niet om het werk af te branden.

1. Managementsamenvatting

De nota beantwoordt de escalatievraag (harmonisatie van authenticatie voor BgZ en eOverdracht) met een op zichzelf verdedigbare keuze: een federatief model op bestaande standaarden. De hoofdlijn is goed te volgen. De belangrijkste verbeterpunten zitten in de **onderbouwing en de structuur**: de tekst presenteert een aantal conclusies vóór de premissen, mengt abstractieniveaus, en gebruikt veel nog niet gedefinieerde begrippen. Daardoor is het stuk voor een kritische lezer op onderdelen lastig te volgen en soms onbedoeld inconsistent.

Vijf **rode draden** verklaren verreweg de meeste losse bevindingen:

1. **De overdrachtscontext ontbreekt.** De escalatie gaat over een *patiëntoverdracht* (de bron stuurt actief een gerichte set; behandelrelatie én toestemming zijn vooraf geregeld). De nota framet het generieker als “gegevens uitwisselen”. Deze premisse draagt zowel de juridische noodzaak-vraag als het threat-model; zonder haar blijven veel argumenten kaler dan nodig.
2. **Nog geen expliciete gelaagdheid (business, patroon, techniek).** Business-vragen worden soms met techniek beantwoord, het communicatiepatroon (*Notified Pull*) wordt nergens benoemd, en enkele eisen landen op het verkeerde niveau. Dit speelt ook in de requirements (bijlage A) en in het diagram.
3. **Pull-frame terwijl het een push is.** Grote delen (§4.1, h5, §5.2, §7.1) zijn geschreven vanuit “iemand vraagt op, wij geven vrij”, terwijl de overdracht juist een actieve verzending is. Dat verklaart ook het verkeerde kernrisico in §7.1.
4. **Veel dragende begrippen en rollen zijn nog niet gedefinieerd.** uitwisselingspartner, aanvrager, intermediair, knooppunt, organisatorisch spoor, stelselbeheerder, zorgtoepassing, “het afsprakenstelsel”, en zelfs “federatief vertrouwensmodel” zijn allemaal dragend maar niet gedefinieerd.
5. **Enkele conclusies en eisen missen nog hun onderbouwing.** Claims (“meest veilige”, “migratievast”, “geen toegevoegde betrouwbaarheid”) en requirements staan zonder herleiding; op meerdere plekken wordt verwezen naar een normsteller / toezichthouder / stelselbeheerder die (nog) niet is benoemd.

Advies op hoofdlijnen: zet de overdrachtscontext en een expliciete lagenopdeling vooraan; definieer de rollen en kernbegrippen één keer; herschrijf de push-delen vanuit het verstuurpatroon; onderbouw of laat de nog niet gedragen claims weg; en houd de governance-laag (normsteller, toezicht, stelselbeheerder) buiten dit concept, of verwijst er kort naar.

2. Belangrijkste issues

De onderstaande punten zijn structureel en raken meerdere plaatsen tegelijk. Details en vindplaatsen staan in deel 3 en in de ruwe notitie.

I. Overdrachtscontext ontbreekt (kaderstellend)

De nota maakt nog niet expliciet dat het om een patiëntoverdracht gaat, met drie gevolgen die de argumentatie zouden dragen: (a) behandelrelatie al vastgesteld vóór de transactie, (b) toestemming/grondslag daarmee al geregeld (verondersteld), en (c) de bron stuurt actief een gerichte set (business: versturen; techniek: Notified Pull). Hierop rusten de juridische noodzaak-vraag en het threat-model. Zie *deel 3*: §0.

II. Nog geen expliciete lagenopdeling

Business, conceptueel-technisch en techniek-uitwerking lopen nu door elkaar. Voorgestelde lagen: business-context, business-patroon, conceptueel technisch (het *Notified Pull*-patroon), en techniek-uitwerking (FAPI/SMART/UDAP). Per laag: welke rol handelt, wat wordt vastgesteld, welke NFR's. Dit lost tal van losse bevindingen in één keer op. Zie *deel 3*: “*Lagenopdeling*”.

III. Frame: pull terwijl het een push is

§4.1, hoofdstuk 5, §5.2 en §7.1 zijn geschreven als bevraging (“opvraging”, “beschikbaar stellen”, “aanvrager”), terwijl de overdracht een verzending is. Een gevolg: §7.1 beschrijft het pull-risico (doorwerking van andermans zwakke proces) en mist het risico dat hier centraal staat, namelijk versturen naar de verkeerde partij. Zie *deel 3*: §4.1, h5, §5.2, §7.1.

IV. Nog niet gedefinieerde begrippen en rollen

Het kernpunt is de dragende term “**uitwisselingspartner**” (15x, nog niet gedefinieerd), die de verschillende juridische rollen op één hoop veegt: bevrager/raadpleger, bevroegde/bron, verzender, ontvanger. Die zou vervangen kunnen worden door specifieke rollen met hun juridische lading. Het speelt breder: ook *aanvrager* (§8.3), *intermediair/knooppunt* (§6.1, feitelijk de **AVG-verwerker**), *organisatorisch spoor / stelselbeheerder* (§7.3), *zorgtoepassing* en “het afsprakenstelsel” (bijlage A) en zelfs *federatief vertrouwensmodel* (§9) zijn nog niet gedefinieerd, en termen wisselen per paragraaf. **Advies:** definieer één rol-/begrippenkader vooraan en gebruik het consistent. Zie *deel 3*: §3.1-1, §5.1, h6-6, §8.3/§8.4, §9.

V. Onderbouwing en governance

- **Nog geen expliciete juridische beschouwing.** De nota leunt op meerdere plekken op juridische argumenten (AVG, dataminimalisatie, Wabvpz) om technische keuzes te dragen, maar zet nog niet vooraf en gezaghebbend neer *wat juridisch nodig is* bij deze uitwisseling. Daardoor functioneert de AVG eerder als losse verwijzing dan als toetssteen. **Advies:** een beknopte, vooropgestelde juridische beschouwing (“hoofdstuk 2”-achtig), bij voorkeur expliciet als door een jurist bevestigd. Dat maakt in één keer duidelijk hoe naar de oplossing wordt gekeken en haalt het motivering-achteraf-gevoel weg. Zie *deel 3*: “*Juridische beschouwing*”.
- **Enkele security-claims missen nog een analyse:** “geen toegevoegde betrouwbaarheid” (§3.1) en “meest veilige combinatie” (§8.4) staan er zonder dreigingsmodel of vergelijking.
- **Nog niet gedragen claim:** “migratievast richting Dezi en Europese wallets” (§9); voor wallets zelfs in spanning met §8.1.
- **Governance past niet in dit concept.** “stelselbeheerder” (§7.3), toezicht/audits (§9) en de normsteller van de requirements (bijlage A) worden aangehaald maar (nog) niet belegd. Voor deze authenticatie-/overdrachtscasus is die governance-laag bijzaak: hij maakt het stuk zwaarder en levert enkele inconsistenties op (o.a. het onevenredige “URA verwijderen”-sanctiemiddel). **Advies:** **laat deze laag weg** en verwijs waar nodig kort naar het afsprakenstelsel, in plaats van hem uit te werken. Zie *deel 3*: §3.1-4, h8, §7.3, §9, *bijlage A*.

VI. Requirements (bijlage A): consistentie en gelaagdheid

Techniek, architectuurprincipe en governance staan nu als gelijkwaardige MOET-bullets door elkaar; een paar eisen zijn onderling in spanning of nog onvolledig. De belangrijkste:

- **ZA.6 tokenvalidatie onvolledig:** nu alleen handtekening; nog geen issuer, expiration, audience of **certificaat-intrekking**. Daardoor heeft het intrekings-sanctiemiddel uit §7.3 in de praktijk geen effect.
 - **ZA.1 en ZA.2 in spanning:** ZA.1 autoriseert op de inhoud (organisatietype/doel), ZA.2 zegt de inhoud niet te valideren.
 - **organisatietype** wordt meermaals verplicht (ZV.3, ZA.1) terwijl de motivering (toestemmingscontrole) in de overdrachtscontext vervalt en het attribuut niet verifieerbaar is.
 - **modaliteit:** ZV.2 zegt “MAG NIET” waar het feitelijk “KAN NIET” is; ZA.7 “MAG” verleent een bevoegdheid waar het stelsel niet over gaat. Zie *deel 3: “Bijlage A”*.
-

3. Details per onderdeel

Onderstaand zijn de bevindingen beknopt samengevat met vindplaats. De volledige uitwerking (met citaten en volledige adviezen) staat per blok in *REVIEW-notitie-ruw.md*.

§0: Overdrachtscontext (kaderstellend)

De nota framet nu generiek (“A deelt met B”, §1.1/§4.1) in plaats van als patiëntoverdracht. Drie pijlers ontbreken nog expliciet: behandelrelatie vooraf vastgesteld, toestemming verondersteld, en een gerichte actieve push (Notified Pull). Hierop rusten de juridische noodzaak en het threat-model. **Advies:** maak de overdrachtssituatie het uitgangspunt (§1.1 en §4.1) en beschrijf het interactiepatroon eenduidig.

§3.1: Interne authenticatie

Conclusie vóór het fundament; vijf punten: (1) “uitwisselingspartner” nog niet gedefinieerd; (2) het juridische en het security-register lopen ongemarkeerd door elkaar; (3) “authenticatieplicht” hangt grammaticaal los, zonder wetsartikel; (4) **“geen toegevoegde betrouwbaarheid” is een security-conclusie zonder dreigingsmodel** (het zwaarste punt); (5) het dataminimalisatie-argument gaat uit van de zwakste vorm van verificatie (verificatie is niet per se de personeelslijst inzien). Onderliggend: het leest nu als motivering achteraf voor de h4-keuze.

eIDAS (§3.1 r. 83 e.v.)

- (1) De kruisverwijzing “(zie §7.2)” loopt dood: daar staat eIDAS/niveau-hoog niet; (2) versie onbepaald en op één plek tegenstrijdig (impliciet 1.0 versus “eIDAS 2.0” op r. 229); (3) de sprong van scope persoon naar verwerking wordt niet gelegd; (4) status “vereist” (r. 83) versus “afgesproken norm” (r. 195). **Advies:** onderbouw op één plek, benoem de versie, en beperk de eis tot het persoonsgebonden inlogmiddel.

§3.2: “kan gebruikgemaakt worden van dit middel” (r. 89)

- (1) “kan” is in spanning met ZA.1 (URA is verplicht én de enige identifier); (2) passief met een vaag onderwerp; (3) “dit middel” vervlakt het onderscheid identificatie (URA) versus authenticatie (UZI-servercertificaat). **Advies:** dwingender formuleren en identificatie/authenticatie scheiden.

Register: spreektaal (hele document)

De toon is nu vrij uitleggerig/mondeling voor een normstellend stuk: “het ene”, “grofweg”, “lijkt op het eerste gezicht”, “bewijsje”, “op orde”, “met andere woorden”, “hoe dan ook”, de A/B-vertelling en de paspoort-analogie. Losse taalfout op r. 33: 3× “mogelijk” in één zin (waarvan een dubbeling). **Advies:** naar een zakelijker register; de analogie kan bewust als illustratie gemarkeerd blijven.

§4.1: Interactiecontext

- (1) Nog geen situatieschets (push of pull?); (2) de rollen wisselen binnen drie zinnen (A stuurt versus B vraagt op); (3) het frame dekt alleen BgZ-pull, niet eOverdracht-push;
- (2) “het ene ontwerpprincipe” (spreektaalig, noemt het principe niet), en optie 1 wordt weer op enkel de AVG afgewezen. **Advies:** beide interactievormen expliciet, rollen consistent.

§4.4: “Bouwstenen” mengt twee categorieën

Vertrouwensvestiging (identificatie/authenticatie/autorisatie/behandelrelatie/toestemming) versus verantwoording achteraf (logging, transparantie). Logging en transparantie vestigen geen vertrouwen; het zijn AVG/Wabvpz-verplichtingen. Nuance: hun bestaan kan vertrouwen indirect versterken, dus randvoorwaarde in plaats van bouwsteen. **Advies:** splitsen; logging/transparantie naar “borging achteraf” (h7).

Hoofdstuk 5: “de zorgverlener logt in”

- (1) Wie logt in? “zorgverlener” en “medewerker” lopen door elkaar; het kan een secretariael medewerker zijn, niet per se BIG; (2) de eigen federatieve logica zegt “maakt niet uit”, maar de nota eist “geldige behandelrelatie” bij de initiator (interne spanning); (3) het pull-frame (“opvraging”, “beschikbaar stellen”) botst met de push-context. **Advies:** initiator = medewerker van de verzender; behandelrelatie = interne verantwoordelijkheid; herschrijf vanuit push.

Lagenopdeling (structureel, na §0 het zwaarst)

Voorgestelde lagen: business-context, business-patroon (gericht versturen), conceptueel technisch (het **Notified Pull**-patroon; hier volstaat “stel de juiste ontvanger vast”), en techniek-uitwerking (FAPI/SMART/UDAP, nu los in h8). Per laag: wie handelt, wat vaststellen, welke NFR’s. **Advies:** structureer h4–8 langs deze lagen en benoem NP expliciet.

§5.1: “uitwisselingspartner”/“opvraging” (rol/niveau)

De rol is niet benoemd; “opvraging” is misleidend (het is de P uit NP, een verstuurpatroon). Op conceptueel niveau volstaat vaststellen dát met de juiste ontvanger wordt gecommuniceerd. **Advies:** concrete rol plus verstuurpatroon; koppel aan de lagenopdeling.

§5.1: “organisatietype nodig voor toestemmingscontrole”

De motivering vervalt: toestemming is in de overdrachtscontext al geregeld (§0). Interne spanning met TRAN.3 (toestemming belegd buiten de transactie). Reikwijdte: organisatietype is een van de drie dragende attributen (r. 153/225/291/292/323/327). **Advies:** schrap de motivering, of herzie het doel (bijvoorbeeld bepalen welk afsprakenstelsel geldt).

§5.2: “juistheid wordt niet gecontroleerd”

- (1) Welke claim, en waarom niet-valideren verantwoord is, ontbreekt (de h4-rechtvaardiging wordt hier niet aangehaald); (2) attributenverklaring en inlogmiddel staan onder één noemer; (3) **rol-omkering:** de bron beslist (r. 155) versus de ontvanger controleert (r. 159); het veronderstelt impliciet nog het bevraagscenario; (4) de kop “transportniveau” dekt de applicatieve inhoud niet. **Advies:** benoem de claim plus de rechtvaardiging; herschrijf de rollen vanuit NP; kies de juiste kop.

Hoofdstuk 6: organisatie-authenticatie

- (1) “URA is de enige organisatie-identificatie” is te absoluut; de nota gebruikt zelf KvK/SBI (r. 277). Beter: UZI/DEZI is het meest gebruikte, vertrouwde *zorgaanbieder*-register. (2) identificatie versus authenticatie causaal scherper leggen;

- (2) **“twee niveaus” is in spanning met §6.2:** mTLS wordt eerst als authenticatie-borging opgevoerd en daarna ongeschikt verklaard. Heldere framing: token = authenticatie, mTLS/LDN = netwerk. (4) LDN/mTLS = netwerk, geen authenticatie; (5) §6.1 “de transactie”: welk niveau?; (6) §6.1 “intermediairs/knooppunten”: de verwijzing “deze” is onhelder, de term is niet nodig (het zijn AVG-**verwerkers**), “knooppunt” valt uit de lucht, en de relevantie is onduidelijk zonder patroon; (7) §6.2 kan expliciteren dat de transportlaag alleen een **gesloten netwerk** maakt (voorsorteren op LDN; certificaat-attributen bewust niet gebruikt).

Ontwerpprincipes (structureel)

Er ontbreekt nog een intro met de uitgangspunten (“werkt vandaag / in gebruik”, “geen nieuwe stelselspecifieke techniek”, “lage implementatielast”, “korte termijn maar migratievast”, “harmonisatie”). Die staan nu verspreid en pas in de conclusie gebundeld. **Advies:** vooraan expliciteren en er in h5–8 naar terugverwijzen.

Juridische beschouwing (structureel)

De nota leunt op meerdere plekken op juridische argumenten (AVG, dataminimalisatie, Wabvpz, verwerkingsverantwoordelijkheid) om technische keuzes te rechtvaardigen, maar zet nog niet expliciet/gezaghebbend neer wat er juridisch nodig is bij de uitwisseling. Nu impliciet en verspreid (§3.1/§3.2/§7.2), waardoor de AVG eerder als losse verwijzing dan als kader functioneert. **Advies:** voeg een vooropgestelde juridische beschouwing toe (“hoofdstuk 2”-achtig): wat is juridisch vereist bij deze overdrachtsuitwisseling (grondslag, verantwoordelijkheden, minimale eisen), bij voorkeur expliciet als door een jurist bevestigd; verwijs er in §3.1/§3.2/§7.2 naar terug. Dit is het juridische pendant van de ontwerpprincipes en sluit aan op punt 0.

§7.1: Kernrisico

Beschrijft het pull-risico (andermans zwakke proces werkt door), maar mist het push-risico dat hier centraal staat: **versturen naar de verkeerde partij** (misrouting), af te dekken met organisatie-authenticatie/adressering. Nuance: het pull-risico geldt wél bij BgZ-bevraging, plus de aansprakelijkheid voor het eigen proces. De ontvanger wordt na ontvangst zelf verwerkingsverantwoordelijke (r. 193). **Advies:** herformuleer vanuit push.

Hoofdstuk 7: matrix, sporen, scope

- (1) **De matrix (r. 189) wordt nog niet ingelost:** alleen §7.3 volgt de drie momenten, 7.2/7.4 niet; (2) toestemming/behandelrelatie zijn aangekondigd (r. 187) maar niet behandeld; (3) het technische spoor (§7.4) is nu een opsomming zonder risico-koppeling en herhaalt §6.2/§8.3; (4) §7.2 (juridisch) heeft hetzelfde; §7.3 is juist het spoor dat het goed doet (Vooraf/Doorlopend/Achteraf); (5) **§7.2 scope-drift:** AVG-rolverdeling en patiëntrechten in plaats van de authenticatievraag; “belegbaar” is jargon; (6) **§7.3** nog niet gedefinieerde begrippen (organisatorisch spoor, toetredingseisen “aan wie?”, stelselbeheerder), technische eisen onder “organisatorisch”, en **URA verwijderen als sanctie is onevenredig** (dat komt feitelijk neer op de zorgaanbieder opheffen; het servercertificaat intrekken is wél proportioneel). NB: deze governance-/sanctielaag kan voor deze casus beter grotendeels wegblijven (zie issue V) in plaats van te worden uitgewerkt; (7) §7.4 presenteert een mechanisme als doel (“bevestigen dat er een geldig certificaat is”); (8) §7.4 “certificaat toont mogelijk alleen het aansluitpunt” is nog niet onderbouwd en in spanning met ZA.2 (**bestaan er generieke UZI-knooppuntcertificaten?** te verifiëren; lijkt geleend uit het LDN-scenario); (9) §7.4 het dragende “identiteit niet aan transport”-argument staat verstopt in plaats van vooraan; (10) §7.4 logging (NEN 7513) is niet relevant voor de authenticatie-context, en “wie (persoon)” is in spanning met het model (over de grens is er geen persoonsniveau).

Hoofdstuk 8: techniek-uitwerking

- **Uitgangspunt “alleen bestaande standaarden” nog niet gemotiveerd**, en het sterkste argument (voorsorteren op EHDS/Euridice) ontbreekt op de plek waar het wordt gedeclareerd.
- **De drie attributen zitten op verschillende niveaus:** alleen URA is een business-attribuut; organisatie-type is hier overbodig; “doel” is een NP-patroonartefact (disambiguatie van de pull), geen business-informatie.

- **§8.1 VC-afwijzing:** vier ongelijke argumenten; het sterkste (nog geen operationele uitgever van een URA-VC) staat niet vooraan; “verificatiebehoefte minimaal” mist het eigenlijke punt; “onevenredige complexiteit” is te stellig (een VC is in de kern ook een ondertekende JWT).
- **§8.1/§8.2 OAuth versus VC:** nu als concurrenten gepositioneerd, terwijl ze complementair zijn (VC-uitgifte draait op OAuth; SD-JWT VC kan het token zijn). De echte keuze is JWT-claims versus VC-formaat *binnen* OAuth.
- **§8.2 nog geen criteria/probleemstelling** vóór de profielvergelijking; “relevant” zonder meetlat.
- **§8.2 voor/nadeel-bullets zijn nog niet weegbaar** (verschillende soorten bezwaren), en er zit een **interne ommezwaai** in: eerst concurrerend, dan “vullen elkaar aan” (r. 259).
- **§8.3 “in plaats van mTLS-clientcertificaat”** veronderstelt een status quo die er nog niet is (het is een greenfield-keuze); risico op verwarring met mTLS-transport.
- **§8.4 “de meest veilige combinatie”** is nog een niet-onderbouwd superlatief zonder vergelijking; de bijzin reduceert de set al tot één.
- **§8.3/§8.4 en het diagram “aanvrager”** is een nieuwe, nog niet gedefinieerde rol-term; pull-taal.
- **Diagram:** “geeft tokens uit” is techniek waar een business-stap hoort; de JWKS-fetch (stap 2) is een overbodige round-trip als met de UZI-cert-sleutel wordt ondertekend (x5c kan mee); de spanning tussen JWKS-publicatie en UZI-cert-keten is nog niet opgelost; en **adressering (GFA / resource-server-URL) ontbreekt**, terwijl juist die borgt dat je met de juiste partij verbindt (§7.1-*risico*). Het diagram kiest nog geen niveau.

§9: Conclusie

- (1) “federatief vertrouwensmodel” is nog niet gedefinieerd (het sluitstuk van de begrippen-kwestie); (2) “de risico’s van dit model” is te vaag, verwijst niet naar h7, en vat een risico-analyse samen die zelf nog niet klopt (§7.1); (3) “audits en toezicht” wordt geclaimd maar nergens uitgewerkt (geen toezichthouder benoemd); voor deze casus beter weglaten dan uitwerken (zie issue V); (4) “migratievast richting Dezi en Europese wallets” is nog niet onderbouwd, voor wallets zelfs in spanning met §8.1; het sterkere argument (EHDS/Euridice) wordt niet ingezet.

Bijlage A: requirements

- **Normsteller en onderbouwing ontbreken nog:** SHALL-eisen zonder aanwijsbare eigenaar/gezag en zonder herleiding; “concept ter bespreking” is in spanning met de stellige MOET-taal; “niet uitputtend, aanvullingen nog” verzwakt de status. (De governance-vraag “wie stelt vast/handhaaft” hoort niet in dit concept, zie issue V; volstaan kan met een korte verwijzing naar het afsprakenstelsel.)
- **Nog geen gelaagdheid:** low-level techniek (ZA.3–6), architectuurprincipe (ZV.2), governance (ZA.1, TRAN.3) en compliance (TRAN.1–2) staan als gelijkwaardige bullets.
- **ZA.7:** “MAG intermediair inzetten” is een lege bevoegdheid (AVG-verwerker; niet aan het stelsel); “end-to-end” zonder gedefinieerde eindpunten.
- **ZA.6:** validatie nog onvolledig; geen issuer/expiration/audience/**intrekking**, waardoor de §7.3-sanctie geen effect heeft; ook de sleutel-trust-binding is niet benoemd.
- **ZV.2:** “MAG NIET” waar het “KAN NIET” is (er is geen data om te verifiëren); een verbod op iets onmogelijks is niet toetsbaar; spanning met §3.1.
- **ZV.3:** organisatietype overbodig; “iedere transactie” nog niet afgebakend (uitzonderingen: het token-verzoek zelf, discovery, health-checks).
- **AUTHZ.ZA.1:** autoriseert op een overbodig én niet verifieerbaar (self-asserted) organisatietype; de SBI/KvK-herkomst is in spanning met “URA is de enige identificatie”.
- **AUTHZ.ZA.2:** doel onduidelijk; geldigheid ontbreekt (valt niet onder “integriteit”); “uitsluitend” sluit een geldigheidscheck uit; in spanning met ZA.1.
- **TRAN.1:** logging is staand recht (NEN 7513/Wabvpz), niet uitwisseling-specifiek.
- **TRAN.2:** idem staand recht; verkeerde scope (inzage gebeurt los in tijd van de transactie); het “volledig overzicht” over beide partijen is nog niet belegd (geen correlerende partij).
- **TRAN.3:** niet relevant voor de verzendcasus (behandelrelatie/toestemming al vooraf); “per zorgtoepassing” en “het afsprakenstelsel” zijn nog niet gedefinieerd.